

POLÍTICA DE SEGURANÇA DA INFORMAÇÃO

Porto Alegre, abril de 2015
Versão 4.0

POLÍTICA DE SEGURANÇA DA INFORMAÇÃO DAS EMPRESAS PERTENCENTES AO GRUPO HOSPITALAR CONCEIÇÃO

1. INTRODUÇÃO

A informação é o dado com uma interpretação lógica ou natural dada a ele por seu usuário (Rezende e Abreu, 2000). A informação tem um valor altamente significativo e pode representar grande poder para quem a possui. A informação contém valor, pois está integrada com os processos, pessoas e tecnologias. Diante da sua importância para as tomadas de decisões, as empresas têm-se empenhado em utilizar mecanismos de segurança no sentido de salvaguardar essas informações.

2. OBJETIVO

A Política de Segurança da Informação do Grupo Hospitalar Conceição – PSI/GHC visa preservar a confiabilidade, integridade e disponibilidade das informações para a resolução de problemas e tomada de decisão, primando por melhorar a qualidade do atendimento e tratamento do paciente. O PSI/GHC é uma declaração formal da instituição acerca de seu compromisso com a proteção das informações de sua propriedade e/ou sob sua guarda, devendo ser cumprida por todos os seus colaboradores no que diz respeito a seus direitos e responsabilidades com os recursos computacionais da instituição e as informações neles armazenados. Seu propósito é estabelecer as diretrizes a serem seguidas pelo GHC no que diz respeito à adoção de procedimentos e mecanismos relacionados à segurança da informação.

3. COMPOSIÇÃO DO PSI/GHC

3.1 – Estrutura Normativa e sua Revisão

A estrutura do PSI/GHC é composta por um conjunto de documentos hierarquicamente descritos a seguir:

- **Política de Segurança da Informação** → constituída por este documento define a estrutura, as diretrizes e as obrigações referentes à segurança da informação. A aprovação deste documento é dada pela Diretoria Executiva e sua revisão deverá ser anual;
- **Normas de Segurança da Informação** → descrevem todas as regras de segurança definidas de acordo com as diretrizes da Política, a serem seguidos em diversas situações em que a informação é tratada. É de responsabilidade do COMITÊ GESTOR DA POLÍTICA E SEGURANÇA DA INFORMAÇÃO DO GHC – CGPSI/GHC aprovar o referido documento, bem como revisá-lo anualmente;
- **Procedimentos de Segurança da Informação** → visam instrumentalizar o disposto nas Normas e na Política. Cabe ao Gerente de Informática aprovar os procedimentos de segurança adotados, devendo este documento ser revisto anualmente.

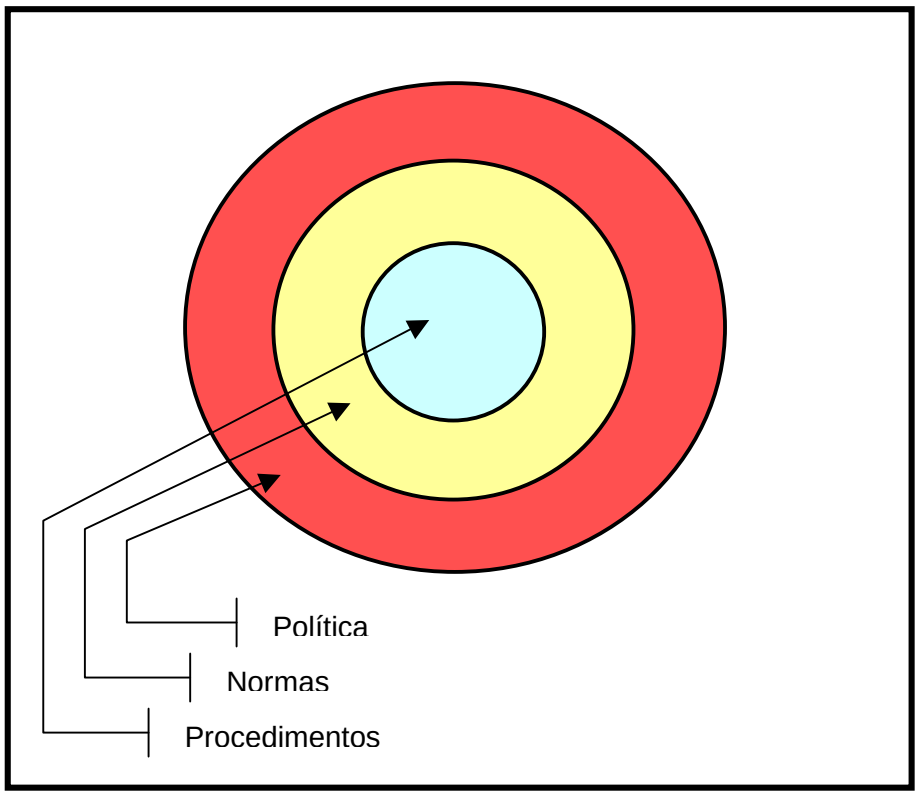


Figura 1 – Estrutura do PSI/GHC

3.2 – Aspectos de Disseminação da Política

A Política e as Normas de Segurança da Informação no GHC devem ser amplamente divulgadas entre os seus colaboradores, devendo estar à disposição para consultas a qualquer momento.

4. COMPOSIÇÃO DO PSI/GHC

Instituído pela Portaria 483/12 o COMITÊ GESTOR DA POLÍTICA E SEGURANÇA DA INFORMAÇÃO DO GHC – CGPSI/GHC, o qual deve ser composto pelos seguintes membros:

- Membro da Diretoria;
- Gerente de Informática;
- Gerente de Controladoria;
- Gerente de Auditoria;
- Gerente de Ouvidoria;
- Gerente Financeiro;
- Gerente de Materiais
- Gerente de Recursos Humanos;
- Gerente de Ensino e Pesquisa;
- Gerente de Engenharia e Patrimônio;
- Gerente do Serviço de Saúde Comunitária;
- Gerentes de Administração das U.H do GHC;
- Gerentes das Unidades de Internação das U.H do GHC;

- Gerente de SADTs do GHC;
- Gerente de Licitação
- Assessor Jurídico;
- Assessor Comunicação Social.

5. DIRETRIZES GERAIS, ATRIBUIÇÕES E RESPONSABILIDADES NO QUE DIZ RESPEITO À GESTÃO DA POLÍTICA DE SEGURANÇA DA INFORMAÇÃO

Cabe a todos os colaboradores (funcionários contratados e cedidos, residentes, doutorandos, estagiários e prestadores de serviços) do GHC:

- Cumprir fielmente a Política, as Normas e os Procedimentos de Segurança da Informação do GHC;
- Buscar orientação do superior hierárquico imediato em caso de dúvidas relacionadas à segurança da informação;
- Assinar Termo de Responsabilidade, formalizando a ciência e o aceite da Política e das Normas de Segurança da Informação, bem como assumindo responsabilidade por seu cumprimento;
- Proteger as informações contra acesso, modificação, destruição ou divulgação não-autorizados pelo GHC;
- Todo pessoal que integra direta ou indiretamente os recursos humanos do GHC é responsável pela segurança da informação, dentro de sua respectiva área de atuação;
- Assegurar que os recursos tecnológicos à sua disposição sejam utilizados apenas para as finalidades aprovadas pelo GHC;
- Cumprir as leis e as normas que regulamentam os aspectos de propriedade intelectual;
- Comunicar imediatamente à área de Gerência de Informática qualquer descumprimento ou violação desta Política e/ou de suas Normas e Procedimentos;
- O uso de equipamentos particulares no âmbito do GHC será controlado e deverá estar em conformidade com as normas de segurança desta PSI;
- Deve ser implementado um programa permanente de conscientização sobre segurança da Informação de forma que seja esclarecido a todos os potenciais riscos de segurança a que estão expostos os ativos de segurança da informação, proporcionando, assim, maior cooperação para o cumprimento das normas desta PSI;
- Todos os Ativos de Segurança da Informação (ler 3.2) serão protegidos por essa PSI, baseando-se em critérios de classificação, criticidade, confidencialidade, risco de exposição, alinhados com as diretrizes estratégicas do GHC;
- Documentos e softwares desenvolvidos por funcionários e prestadores de serviço são de propriedade do GHC, ressalvados em casos expressamente assegurados por contrato formal;
- As informações de propriedade do GHC devem ser de uso restrito para os fins a que se destinam, não podendo, sob nenhum propósito, serem apropriadas ou divulgadas a terceiros;
- Todas as informações devem ser protegidas contra perda, acessos e usos indevidos, devendo ser adotados procedimentos específicos e adequados ao grau de criticidade da informação, sob a responsabilidade direta do funcionário ou prestador de serviço que a detém em sua guarda;
- Esta Política de Segurança da Informação deve ser considerada como subsídio essencial para confecção de processos de aquisição de bens e serviços de Tecnologia da Informação;

- Os softwares adquiridos ou desenvolvidos devem obedecer às especificações de segurança estabelecidas por essa PSI;
- O cumprimento da Política de Segurança da Informação será acompanhado e auditado, sendo permitido, para isso, o monitoramento do tráfego e armazenamento de informação.

Adicionalmente, são definidas as seguintes responsabilidades e atribuições específicas relacionadas à segurança da informação:

5.1. DIRETORIA EXECUTIVA

Em relação à segurança da informação, cabe à Diretoria do GHC:

- Aprovar a Política de Segurança da Informação e suas revisões;
- Aprovar a nomeação dos "proprietários" da informação;
- Tomar as decisões administrativas referentes aos casos de descumprimento da Política e/ou de suas Normas encaminhados pelo CGPSI/GHC.

5.2. COMITÊ GESTOR DA POLÍTICA E SEGURANÇA DA INFORMAÇÃO DO GHC – CGPSI/GHC

Cabe ao CGPSI/GHC:

- Propor ajustes, aprimoramentos e modificações desta Política;
- Propor melhorias e aprovar as Normas de Segurança da Informação;
- Definir a classificação das informações pertencentes ou sob a guarda do GHC, com base no inventário de informações apresentado pela Gerência de Informática e nos critérios de classificação constantes de Norma específica;
- Analisar os casos de violação desta Política e das Normas de Segurança da Informação, encaminhando-os à Diretoria do GHC, quando for o caso;
- Propor projetos e iniciativas relacionados à melhoria da segurança da informação do GHC;
- Propor o planejamento e a alocação de recursos financeiros, humanos e de tecnologia, no que tange à segurança da informação;
- Determinar a elaboração de relatórios, levantamentos e análises que dêem suporte à gestão de segurança da informação e à tomada de decisão;
- Acompanhar o andamento dos principais projetos e iniciativas relacionados à segurança da informação;
- Propor a relação de "proprietários" das informações do GHC.
- Instituir e divulgar a Política de Segurança da Informação – PSI no GHC;
- Analisar os trabalhos de análise de vulnerabilidade realizados pela área de Gestão de Segurança da Informação da Gerência de Informática;
- Proteger as informações contra acesso, modificação, destruição ou divulgação não-autorizados;
- Assegurar que os recursos tecnológicos à sua disposição sejam utilizados apenas para as finalidades aprovadas pelo GHC;
- Outras atribuições que o CGPSI/GHC venha julgar relevante para o interesse e garantia da segurança das informações do GHC.

Os membros que compõe o CGPSI/GHC são definidos pela Portaria 483/12, conforme descrito no capítulo 4.

A direção e/ou coordenação dos trabalhos do CGPSI/GHC será de responsabilidade do Gerente de Informática, cujas atribuições abrangerão a convocação das reuniões e a realização de outros atos de suporte às atividades desenvolvidas.

a) As reuniões do CGPSI:

- Serão realizadas trimestralmente, podendo haver convocação em freqüência maior ou extraordinariamente, sempre que necessário;
- Serão instaladas com a presença de, no mínimo, 2/3 (dois terços) dos membros do CGPS/GHCI;
- Deverão ser registradas em ata.

O CGPSI/GHC deliberará por maioria dos votos presentes.

De acordo com a necessidade, outros profissionais do GHC e convidados externos poderão participar das reuniões do CGPSI/GHC.

5.3. ÁREA DE GESTÃO DE SEGURANÇA DA INFORMAÇÃO

É de responsabilidade da área de Gestão de Segurança da Informação da Gerência de Informática:

- Convocar, coordenar, lavrar atas e prover apoio às reuniões do CGPSI/GHC;
- Prover todas as informações de gestão de segurança da informação solicitadas pelo CGPSI;
- Prover ampla divulgação da Política e das Normas de Segurança da Informação para todos os colaboradores do GHC;
- Oferecer orientação sobre a Política de Segurança da Informação e suas Normas a todos os colaboradores do GHC;
- Propor projetos e iniciativas relacionados ao aperfeiçoamento da segurança da informação para o GHC, mantendo-se atualizada em relação às melhores práticas existentes no mercado e em relação às tecnologias disponíveis;
- Estabelecer procedimentos e realizar a gestão dos sistemas do GHC, bem como do seu controle de acesso, incluindo os processos de concessão, manutenção, revisão e suspensão de acessos aos usuários;
- Analisar os riscos relacionados à segurança da informação do GHC e apresentar relatórios periódicos sobre tais riscos ao CGPSI/GHC, acompanhados de proposta de aperfeiçoamento do ambiente de controle da segurança, quando for o caso;
- Realizar trabalhos de análise de vulnerabilidade, com o intuito de aferir o nível de segurança dos sistemas de informação e dos demais ambientes em que circulam as informações do GHC;
- Requisitar informações às demais áreas do GHC (diretorias, gerências coordenações etc.), realizar testes e averiguações em sistemas e equipamentos, com o intuito de verificar o cumprimento da Política e das Normas de Segurança da Informação;
- Implantar procedimento para ativar e manter registros de vulnerabilidades e ataques reportados por fontes confiáveis[1], além de medidas de controle e correção, promovendo-se, quando necessário, as devidas orientações de intervenção aos administradores dos recursos vulneráveis; e
- Estabelecer mecanismo de registro e controle de não-conformidade a esta Política e às Normas de Segurança da Informação, comunicando o CGPSI/GHC.

5.3.1 Administrador de Sistema / Operações:

→ Todas as informações sobre os usuários serão tratadas como confidenciais;

→ Não será permitido acesso não-autorizado a informações confidenciais;

[1] A principal fonte é a Rede Nacional de Ensino e Pesquisa – RNP, através do Centro de Atendimento a Incidentes de Seguranças – CAIS, acesso pelo site http://www.rnp.br/cais/.

→ Assegurar todas as ações consistentes com o código de conduta de um administrador de sistemas;
→ Adequar os sistemas computacionais e de comunicação em conformidade com a Política de Segurança;

5.3.2 Administrador de Segurança:

→ Mais alto nível de conduta ética;
→ Assegurar todas as ações consistentes com o código de conduta de um responsável pela segurança;
→ Adequar os sistemas computacionais e de comunicação em conformidade com a Política de Segurança;
→ Monitorar os registros dos sistemas;

5.4. PROPRIETÁRIO DA INFORMAÇÃO

O proprietário da informação é um gerente ou um coordenador do GHC, formalmente indicado pela Diretoria do GHC, responsável pela concessão, manutenção, revisão e cancelamento de autorizações de acesso a determinado conjunto de informações pertencentes à instituição ou sob a sua guarda.

Cabe ao proprietário da informação:

- Elaborar, para toda informação sob sua responsabilidade, matriz ou planilha que relacione cargos e funções às autorizações de acesso concedidas;
- Autorizar a liberação de acesso à informação sob sua responsabilidade, observadas a matriz ou planilha de cargos e funções, a Política e as Normas de Segurança da Informação do GHC;
- Manter registro e controle atualizados de todas as liberações de acesso concedidas, determinando, sempre que necessário, a pronta suspensão ou alteração de tais liberações;
- Reavaliar, sempre que necessário, as liberações de acesso concedidas, cancelando aquelas que não forem mais necessárias;
- Analisar os relatórios de controle de acesso fornecidos pela área de Gestão de Segurança da Informação, com o objetivo de identificar desvios em relação à Política e às Normas de Segurança da Informação, tomando as ações corretivas necessárias;
- Participar da investigação de incidentes de segurança relacionados à informação sob sua responsabilidade;
- Participar, sempre que convocado, das reuniões do COMITÊ GESTOR DA POLÍTICA E SEGURANÇA DA INFORMAÇÃO DO GHC – CGPSI/GHC, prestando os esclarecimentos solicitados.

5.5. ASSESSORIA JURÍDICA

Cabe à Diretoria Jurídica:

- Manter as áreas do GHC informadas sobre eventuais alterações legais e/ou regulatórias que impliquem responsabilidade e/ou ações envolvendo a gestão de segurança da informação;
- Incluir, na análise e na elaboração de contratos, sempre que necessário, cláusulas específicas relacionadas à segurança da informação, com o objetivo de proteger os interesses do GHC;

- Avaliar, quando solicitada, as Normas e os Procedimentos de Segurança da Informação elaborados pelas diversas áreas do GHC; e
- Tomar as providências jurídicas cabíveis em casos de incidentes de segurança;

5.6. GERÊNCIAS E COORDENAÇÕES

Cabe às Gerências e Coordenações:

- Cumprir e fazer cumprir esta Política, as Normas e os Procedimentos de Segurança da Informação;
- Assegurar que suas equipes possuam acesso e conhecimento da Política, das Normas e dos Procedimentos de Segurança da Informação;
- Redigir os Procedimentos de Segurança da Informação relacionados às suas áreas, mantendo-os atualizados;
- Comunicar imediatamente eventuais casos de violação de segurança da informação à área de Gestão de Segurança da Informação.

5.7. ÁREA DE RECURSOS HUMANOS

Cabe à área de Recursos Humanos:

- Colher a assinatura do Termo de Responsabilidade dos funcionários e estagiários, arquivando-o nos respectivos prontuários;
- Informar aos ingressos sobre a Política, Normas e Procedimentos de Segurança da Informação adotados pelo GHC;
- Elaborar e aplicar, sob a orientação da área de Gestão da Segurança da Informação da Gerência de Informática do GHC, treinamento sobre Segurança da Informação no GHC, sempre que necessário;
- Informar, prontamente, à área de Gestão de Segurança da Informação, todos os desligamentos, afastamentos e modificações no quadro funcional da empresa;
- Tomar as providências administrativas no caso de aplicação de penalidades aos trabalhadores quanto ao não cumprimento da Política de Segurança da Informação;

5.8. GERAL

Cabe a todos os usuários da rede do GHC:

- Tomar conhecimento dessa política;
- Seguir todas as ações de acordo com essa política;
- Informar à segurança qualquer violação conhecida a essa política;
- Informar à segurança qualquer suspeita de problemas com essa política.
- Sugerir medidas que possam elevar os níveis de segurança das instalações na sua área de atuação;

6. PRIVILÉGIOS

a) Funcionário, residente, doutorando ou estagiário:
    - Acesso a máquinas especificamente autorizadas na forma em que encontra especificamente autorizada;
    - Solicitará autorização prévia por escrito para qualquer ação que possa ser interpretada como uma questão de segurança.

b) Contratado ou convidado[2]:
   - Nenhum acesso a recursos de computação, a menos que haja notificação prévia por escrito à segurança.

7. PENALIDADES

A não observância dos preceitos desta Política poderá implicar na aplicação de sanções administrativas, cíveis e penais previstas na legislação em vigor que regule ou venha regular a matéria.

As penalidades administrativas serão aplicadas após a sua devida apuração em processo administrativo disciplinar, sendo observados critérios de gravidade e reincidência dos atos de violação cometidos à Política de Segurança da Informação.

As infrações ocorridas violando as normas que compõem a Política de Segurança da Informação deverão ser analisadas pelo gestor imediato do infrator, que deverá comunicar imediatamente a Gerência de Informática para fins de determinação da apuração das eventuais responsabilidades dos funcionários envolvidos.

8. DIRETRIZES GERAIS DA SEGURANÇA DA INFORMAÇÃO

As Diretrizes Gerais da Política de Segurança da Informação apontam os principais aspectos e propõem as características dirigidas para todo o conjunto de normas específicas, padrões, procedimentos, manuais, planos e demais documentos relacionados à Segurança da Informação no âmbito do GHC.

Todos esses instrumentos deverão seguir os princípios elencados nessa norma de diretrizes gerais. Essas regras norteadoras, embora estejam unidas numa mesma idéia, foram divididas para uma melhor compreensão em:

a) Gestão de Segurança da Informação – Conjunto de medidas que visam à proteção dos ativos de segurança da informação, conforme capítulo 5;
b) Gestão de Riscos – Conjunto de medidas que buscam atenuar os riscos da informação, identificados através de análise. A Análise de Risco será feita periodicamente, emitindo relatório, quando necessário, para apresentação e análise junto à Diretoria, ao Comitê Gestor de Política e Segurança da Informação e demais Gestores do GHC;
c) Plano de Continuidade de Negócio – Plano desenvolvido através da identificação de causas que possam afetar a disponibilidade dos serviços, trazendo soluções para seu imediato restabelecimento, visando garantir a não interrupção dos serviços críticos nos ambientes computacionais;
d) Plano de Ação e Resposta a Incidentes – Plano que propõe medidas de resposta na ocasião de incidentes de segurança.

9. ATITUDES DE COMPORTAMENTO SEGURO

Independentemente do meio ou da forma em que exista, a informação está presente no trabalho de todos os profissionais. Portanto, é fundamental para a proteção e salvaguarda das informações que os profissionais adotem comportamento seguro e consistente com o objetivo de proteção das informações do GHC, com destaque para os seguintes itens:

[2] Nesta categoria incluem-se auditores externos, analistas e técnicos contratados, visitantes, pacientes e outros não relacionados no capítulo 6 item a.

- Diretores, gerentes, coordenadores, funcionários, residentes, doutorandos, estagiários e prestadores de serviços devem assumir atitude pró-ativa e engajada no que diz respeito à proteção das informações do GHC.
- Os colaboradores do GHC devem compreender as ameaças externas que podem afetar a segurança das informações da empresa, tais como vírus de computador, interceptação de mensagens eletrônicas, grampos telefônicos etc., bem como fraudes destinadas a roubar senhas de acesso aos sistemas de informação.
- Todo tipo de acesso à informação do GHC que não for explicitamente autorizado é proibido.
- Informações confidenciais do GHC não podem ser transportadas em qualquer meio (CD, DVD, disquete, *pen-drive*, papel etc.) sem as devidas autorizações e proteções.
- Assuntos confidenciais de trabalho não devem ser discutidos em ambientes públicos ou em áreas expostas (aviões, restaurantes, encontros sociais etc.).
- As senhas de usuário são pessoais e intransferíveis, não podendo ser compartilhadas, divulgadas a terceiros (inclusive colaboradores da própria empresa), anotadas em papel ou em sistema visível ou de acesso não-protegido.
- Somente softwares homologados pelo GHC podem ser instalados nas estações de trabalho, o que deve ser feito, com exclusividade, pela equipe da Gerência de Informática.
- A política para uso de *internet* e correio eletrônico deve ser rigorosamente seguida. Arquivos de origem desconhecida nunca devem ser abertos e/ou executados.
- Documentos impressos e arquivos contendo informações confidenciais devem ser adequadamente armazenados e protegidos.
- Qualquer tipo de dúvida sobre a Política de Segurança da Informação e suas Normas deve ser imediatamente esclarecido com a área de Gestão de Segurança da Informação da Gerência de Informática do GHC.

10. BIBLIOGRAFIA

[1] ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS (ABNT). NBRISO/IEC27001, Tecnologia da informação - Técnicas de segurança - Sistemas de gestão de segurança da informação – Requisitos, mar. de 2006.

[2] LAUREANO, Marcos Aurélio Pchek - UMA ABORDAGEM PARA A PROTEÇÃO DEDETECTORES DE INTRUSÃO BASEADA EM MÁQUINAS VIRTUAIS. Dissertação de mestrado apresentada ao Programa de Pós-Graduação em Informática Aplicada da Pontifícia Universidade Católica do Paraná como requisito parcial para obtenção do título de Mestre em Informática Aplicada, 2004.

[3] LAUREANO, Marcos Aurélio Pchek – GESTÃO DE SEGURANÇA DA INFORMAÇÃO. Arquivo baixado dia 07 de julho de 2011, do site: http://www.mlaureano.org/ensino/gestao-da-seguranca/.